

Bonus Filled Example: Completed Vendor Review

Purpose: Show what a realistic completed AI vendor review looks like, including a filled decision memo, so you can copy the level of detail instead of starting from blank fields.

How To Read It

This example is fictional. The vendor, answers, and conditions are invented to show one practical documentation style. Copy the level of detail, not the exact facts. Your data, contracts, and risk tolerance will be different, and some reviews will need qualified legal, privacy, security, or procurement help that this example does not replace.

Example Scenario

Organization: Brightside Tutoring, a twelve-person tutoring company.

Request: The operations lead wants to adopt "ReplyDesk AI," a customer-support tool with an AI feature that drafts replies to parent emails using the message history in the support inbox.

Why it escalated past the lite checklist: The support inbox contains parent and student names, scheduling details, and billing references - so the data triage stop trigger applied and the full questionnaire was used.

Questionnaire Highlights

What the reviewer recorded from vendor materials and two emails with the vendor:

Use (Sections 1-3)

- Use case: draft replies to routine parent emails; a staff member reviews and sends every reply.
- Users: four support staff.
- Decisions about people: No - drafting only, no scoring, routing, or eligibility decisions.
- Output destination: customer-facing, always with human review.
- Failure impact: a wrong or tone-deaf draft could be sent if review is skipped; no livelihood/safety impact.

Data (Sections 2, 6)

- Data in scope: parent names, email addresses, message history, scheduling and billing references. Student details appear in some messages.
- Prohibited even if approved: payment card numbers, health or accommodation details, anything beyond what parents already wrote in the thread.
- Retention: vendor stores message data for the life of the account; deleted within 30 days of termination (per DPA).
- Training: vendor does not train on customer data by default for business-tier accounts - confirmed in the DPA, not just the marketing site.

Security (Section 7)

- SOC 2 Type II report available under NDA (reviewed; no open critical findings noted).
- Encryption in transit and at rest; SSO not available on this tier, MFA is.
- No material incidents disclosed in the last 24 months.

AI controls (Section 8)

- Drafts-only mode can be enforced for the whole workspace (auto-send can be disabled by admin). This became an approval condition.

- Vendor publishes a short model-change notice in the changelog; no advance notice for model swaps. Flagged as a watch item.

Legal/contract (Section 9)

- DPA available and signed before rollout.
- Inputs remain customer property; vendor takes a limited license to operate the service.
- No IP indemnity for AI drafts - acceptable here because staff rewrite drafts before sending.

Exit (Section 10)

- Mailbox history exportable as CSV; deletion within 30 days of termination.

Red Flags Checked

Two items from the red flag list applied and were handled:

1. "Model changes can materially change behavior without notice." Response: accepted with a condition - the office manager checks the vendor changelog monthly and re-runs ten saved test replies after any model change.
2. "Users plan to paste or upload whatever is convenient." Response: do-not-paste rules added to the approval notice (no payment data, no health or accommodation details, no documents from student files).

Filled Decision Memo

Vendor: ReplyDesk AI (fictional)

Product / feature: AI reply drafts in shared support inbox

Business owner: Operations lead

Reviewer: Founder

Date reviewed: 2026-05-20

Review type: Full vendor assessment

Decision: Approved with conditions

Risk tier: Medium

Approved use: Drafting replies to routine parent emails in the main support inbox. A staff member reviews, edits, and sends every reply.

Users allowed: The four named support staff.

Approved data categories: Existing support-thread content (names, scheduling, billing references already in the thread).

Prohibited data categories: Payment card numbers; health or accommodation details; student file documents; anything a parent has not already written into the thread.

Evidence reviewed: Privacy policy; terms; signed DPA; SOC 2 Type II (under NDA); vendor email answers on retention and training; internal use-case notes.

Conditions:

1. Auto-send disabled workspace-wide; drafts-only mode enforced by admin setting before rollout.

2. MFA required for all four users.
3. DPA signed before first use (done 2026-05-19).
4. Do-not-paste rules circulated to support staff with the rollout note.
5. Office manager checks the vendor changelog monthly and re-runs ten saved test replies after any model change.
6. Re-review in 6 months, at renewal, or if the use expands beyond routine replies.

Open issues: No SSO on this tier - revisit if the team grows past ten support users. No advance notice for model changes - mitigated by condition 5.

Follow-up actions:

Action	Owner	Due date	Status
Add to AI use inventory	Office manager	2026-05-22	Done
Configure drafts-only and MFA	Operations lead	2026-05-22	Done
Circulate do-not-paste rules	Operations lead	2026-05-23	Done
Calendar 6-month re-review	Office manager	2026-11-20	Scheduled

Next review date: 2026-11-20

Why This Example Landed On "Approved With Conditions"

- The data was real customer data, but limited to what parents already wrote into support threads.
- Human review was enforceable by an admin setting, not just a promise.
- The vendor could produce a DPA, a SOC 2 report, and a written no-training answer - in writing, not just on the marketing site.
- The remaining gaps (no SSO, no model-change notice) were real but manageable with named conditions and a review date.

A vendor that could not answer the training question, refused a DPA, or required auto-send would have pushed this review toward rejection or a narrower public-data-only scope.

Disclaimer

This document is a fictional example for educational and informational purposes only. It is not legal advice, does not create an attorney-client relationship, and does not evaluate any real vendor. Consult qualified counsel and appropriate privacy, security, procurement, HR, and technical reviewers for actual vendor decisions.